WEB APPLICATION SECURITY ASSESSMENT REPORT

1. EXECUTIVE SUMMARY

This report presents the results of a web application security assessment performed on the Damn Vulnerable Web Application (DVWA). The objective of this assessment was to identify security vulnerabilities, exploit them in a controlled environment, and provide remediation recommendations.

The assessment revealed multiple critical vulnerabilities including SQL Injection, Cross-Site Scripting (XSS), Command Injection, and Unrestricted File Upload. These vulnerabilities could allow attackers to gain unauthorized access, execute arbitrary commands, and compromise the system.

2. OBJECTIVE

The primary objectives of this assessment were:

- To identify security vulnerabilities in the web application
- To exploit vulnerabilities in a controlled environment
- To understand real-world attack scenarios
- To provide mitigation strategies

3. SCOPE

- **Target Application:** DVWA (Damn Vulnerable Web Application)
- **Environment:** Localhost (127.0.0.1:8080)
- **Testing Type:** Black-box testing
- **Tools Used:** Burp Suite, Firefox Browser, Kali Linux

4. METHODOLOGY

The following methodology was used during testing:

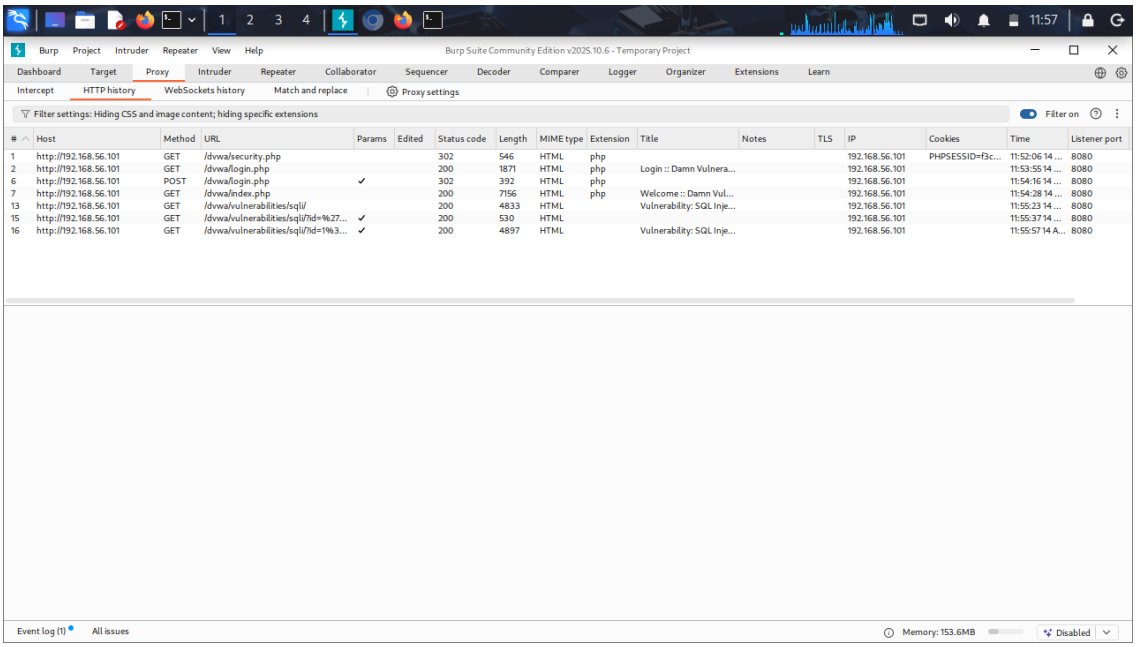
1. Application reconnaissance and exploration

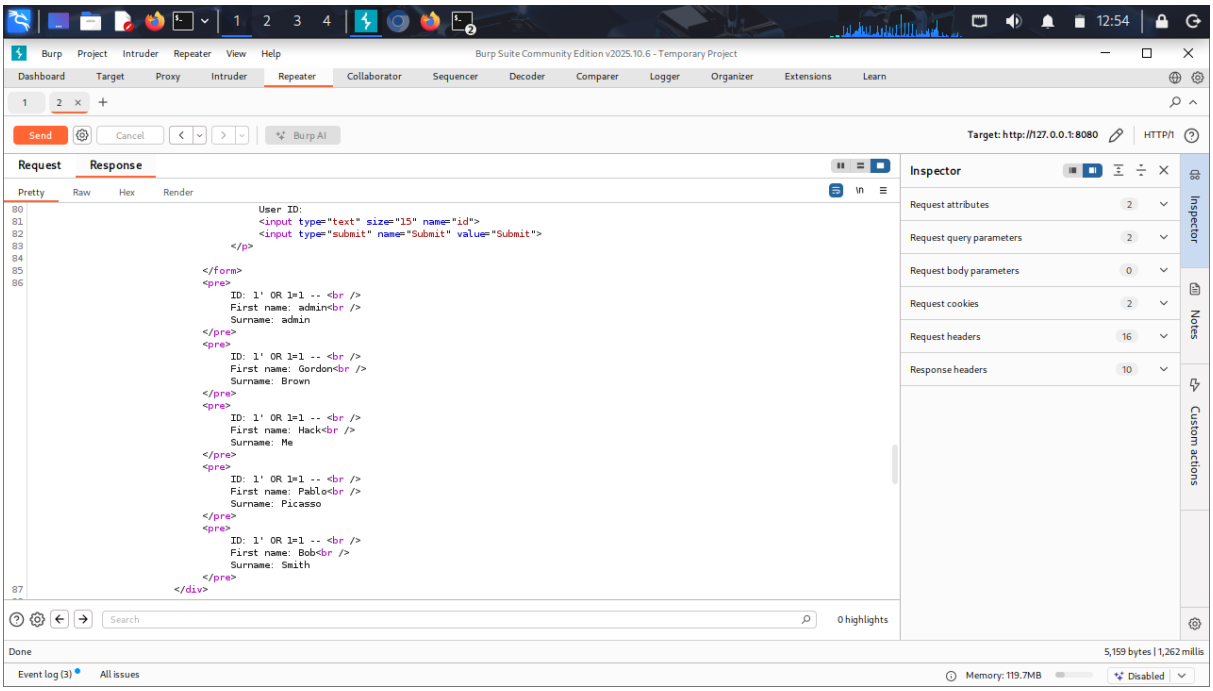
2. Intercepting HTTP requests using Burp Suite
3. Identifying input fields vulnerable to injection
4. Performing manual exploitation
5. Capturing proof of concept (PoC)
6. Documenting findings

5. VULNERABILITY DETAILS

5.1 SQL INJECTION

- **Description:**
  SQL Injection is a vulnerability that allows attackers to manipulate database queries by injecting malicious SQL code into input fields.
- **Payload Used:**
  ' OR 1=1 --
- **Proof of Concept:**
  The payload bypassed query conditions and returned all records from the database, including multiple user entries.
- **Impact:**
- Unauthorized data access
- Database information disclosure
- Authentication bypass
- **Severity:** High
- **Remediation:**
- Use prepared statements (parameterized queries)
- Implement input validation
- Use ORM frameworks



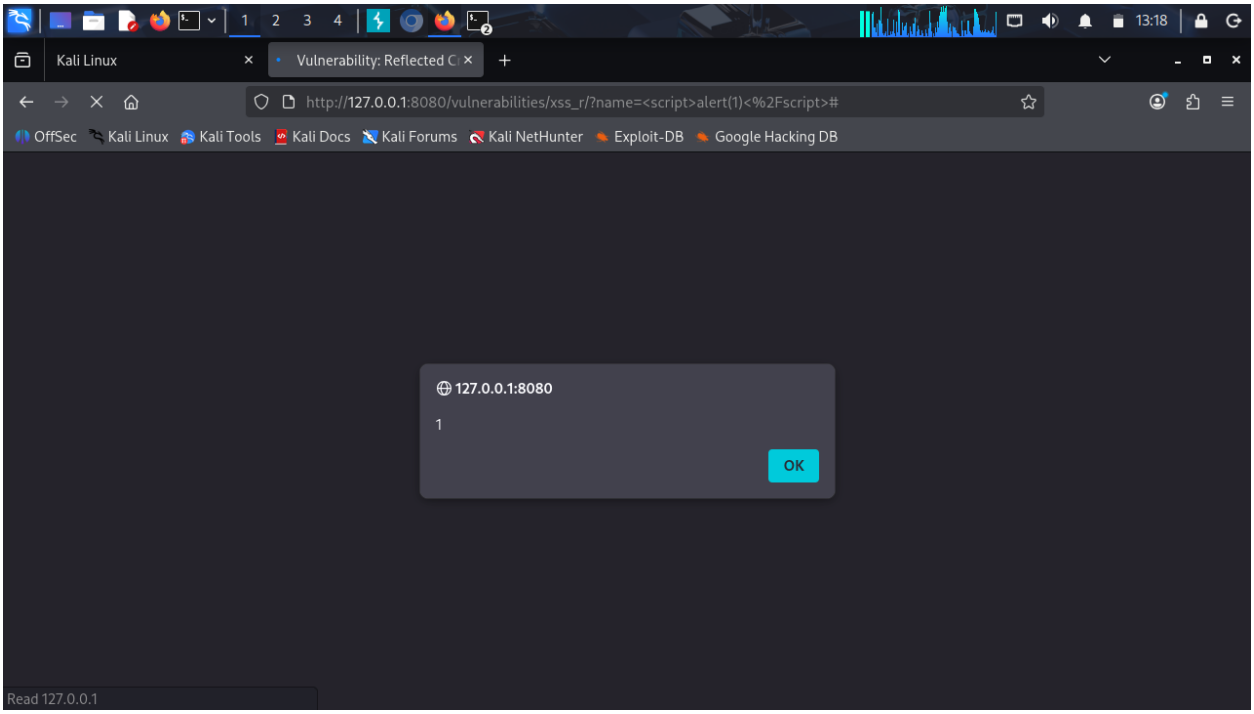


5.2 CROSS-SITE SCRIPTING (XSS)

- **Description:**
  XSS allows attackers to inject malicious JavaScript into web pages, which is executed in the victim's browser.

- **Payload Used:**

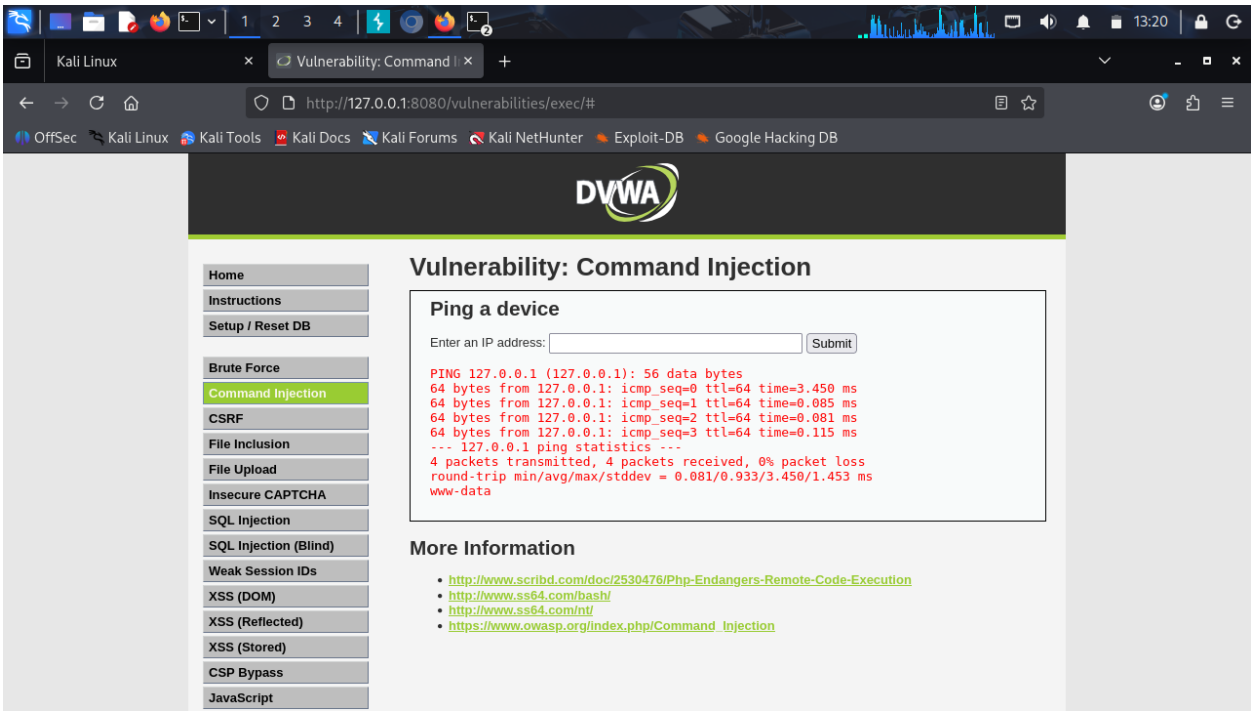
- **Proof of Concept:**
  A JavaScript alert box was successfully executed in the browser.
- **Impact:**
- Session hijacking
- Cookie theft
- Malicious script execution
- **Severity:** Medium
- **Remediation:**
- Input sanitization
- Output encoding
- Use Content Security Policy (CSP)



5.3 COMMAND INJECTION

- **Description:**
  Command Injection allows attackers to execute system-level commands via user input.

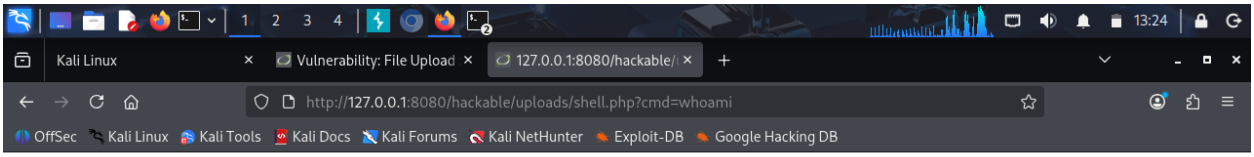
- **Payload Used:**
  127.0.0.1 && whoami
- **Proof of Concept:**
  The application executed the command and returned the system user "www-data".
- **Impact:**
- Remote command execution
- System compromise
- Unauthorized access
- **Severity:** Critical
- **Remediation:**
- Avoid using system-level functions
- Validate and sanitize input
- Use safe APIs



5.4 UNRESTRICTED FILE UPLOAD

- **Description:**
  This vulnerability allows attackers to upload malicious files that can be executed on the server.

- **Payload Used:**
  PHP web shell (shell.php)
- **Proof of Concept:**
  The uploaded file was executed using:
  ?cmd=whoami
  which returned "www-data".
- **Impact:**
- Remote code execution
- Full server compromise
- Backdoor creation
- **Severity:** Critical
- **Remediation:**
- Restrict file types
- Validate file content
- Store files outside web root
- Disable execution permissions



www-data

6. RISK SUMMARY

Vulnerability	Severity
SQL Injection	High
XSS	Medium
Command Injection	Critical
File Upload	Critical

7. CONCLUSION

The application is highly vulnerable to multiple security flaws due to insufficient input validation and insecure coding practices. Immediate remediation is required to prevent exploitation.

8. RECOMMENDATIONS

- Implement strong input validation
- Use secure coding standards
- Regularly perform security testing
- Keep software updated
- Apply least privilege principle

9. DISCLAIMER

This assessment was conducted in a controlled environment for educational purposes only. No real systems were harmed during testing.